

Connect ONG — Entrega Final

Melhorias a partir da banca de qualificação e da FECITEC 2026 · relatório de mudanças, rastreabilidade (seção 4.2) e retrospectiva (seção 4.3)

EQUIPE

Gabriel Chinelatto · Abner Viola ·
Luan Felipe · Arthur Souza

SISTEMA NO AR

Site: connectong.netlify.app
App: gabriel-
chinelatto.github.io/connect-ong

REPOSITÓRIOS

github.com/Gabriel-Chinelatto —
connect-ong, connect-ong-desktop,
connect-ong-api, connect-ong-web

DATA

Setembro de 2026

1. Resumo

Na FECITEC o projeto recebeu média **6,6**. As notas mais altas foram em Interface (9), Arquitetura (9), Impacto e Ética (9) e Inovação (8). As mais baixas foram em **Segurança e Privacidade (3)**, **Modelo de Negócios (4)** e **Análise de Dados (5)**, e o avaliador 2 resumiu o principal problema técnico: *"não tinha validações nos campos, podia colocar o que quisesse em tudo"* e *"não tem criptografia em dados sensíveis ou LGPD"*. Este documento mostra o que foi feito para cada ponto, onde conferir e o que ficou para depois (com o motivo).

11 de 12

itens Must entregues (+2
de 3 Should)

430

testes automatizados
verdes (eram 344)

86

testes novos, só desta
entrega

4

frentes alteradas: API, app,
painel e site

1

defeito grave achado e
corrigido (site fora do ar)

2. Tabela de rastreabilidade (seção 4.2)

Os IDs são os do Plano de Ação. Commits em github.com/Gabriel-Chinelatto/<repositório>/commit/<código>. "Print" são as figuras da seção 3. Os testes citados rodam a cada push (GitHub Actions).

Item	O que foi pedido → o que foi feito	Status	Responsável	Evidência (onde conferir)
B-01	Pouca interação → feed, notificações, sequência e conquistas (já entregues)	Feito	Arthur	Mantidos; suítes do app (124) e do painel (75) verdes. Vídeo: bloco "O que a banca pediu".

Item	O que foi pedido → o que foi feito	Status	Responsável	Evidência (onde conferir)
B-02	Sem comunicação doador ↔ ONG → chat, agora com mensagens cifradas	Feito	Luan	Teste <code>f03_telefoneEMensagemFicamCifradosNoBanco_eLegiveisNaApi</code> (backend). Commit API <code>061c300</code> .
B-03	Match com chat automático após o aceite	Feito	Gabriel	Fluxo em produção desde a v1.0; demonstrado no vídeo (doador demonstra interesse → ONG aceita → chat abre).
B-04	Experiência pouco dinâmica → Dora (IA), mapa, ranking, prestação de contas	Feito	Abner	Recursos no ar nos 3 frontends; print 3.7 (Dora com o aviso novo).
F-01	Validação de formato na API	Feito	Luan	Pacote <code>validacao/</code> (Regras, Telefone, Cnpj, NomeProprio, TextoLegivel, Uf, SenhaForte, PeriodoCampanha). 26 testes em <code>RegrasFormatoTest</code> + 4 em <code>PlanoDeAcaoTest</code> . Commit API <code>061c300</code> . Seção 3.1.
F-02	As mesmas regras nas telas, com máscara	Feito	Abner	<code>utils/validadores.dart</code> (app e painel, 23 testes cada) e <code>js/validadores.js</code> (site). Commits: app <code>514f79b</code> , painel <code>654f7f3</code> , site <code>ca603e0</code> . Print 3.1.
F-03	Criptografia de dados sensíveis	Feito	Gabriel	AES-256-GCM no telefone, no chat e nas denúncias; códigos de verificação em HMAC. 5 testes (cifra, IV aleatório, adulteração detectada, migração do legado, trava de chave). Status ao vivo: <code>/publico/seguranca</code> . Seção 3.2.
F-04	LGPD	Feito	Abner	Consentimento gravado (versão, data, IP); <code>GET /usuarios/{id}/meus-dados</code> ; exclusão com anonimização; política reescrita. 3 testes. Prints 3.3, 3.4, 3.5.
F-05	Segurança pouco abordada	Feito	Arthur	Página "Segurança e LGPD" no site (print 3.3) e a seção 5 deste documento. O bloco no vídeo segue o roteiro da seção 7.
F-06	Pouco pensado para o mercado	Feito	Arthur	Modelo de negócios na seção 4: Lean Canvas, segmentos, concorrência, receita, custos, mercado e metas.
F-07	O mercado visível no produto	Feito	Abner	Página "Para empresas" no site (print 3.6). Commit site <code>ca603e0</code> .
F-08	Análise de dados e resultados	Feito	Luan	<code>/publico/indicadores</code> e <code>/ongs/{id}/indicadores</code> ; teste <code>f08_indicadoresDaOng_funilTaxasEMediana</code> confere cada número contra um cenário montado à mão. Prints 3.8 e 3.9.
F-09	Resultados com usuários reais	Não feito	Arthur	Depende da equipe ir às ONGs de Limeira e aplicar o formulário; a ferramenta para medir (F-08) já está pronta. Previsto até a banca final.

Item	O que foi pedido → o que foi feito	Status	Responsável	Evidência (onde conferir)
F-10	Uso consciente da IA	Feito	Gabriel	RedatorDadosPessoais remove e-mail, telefone, CPF e CNPJ antes do envio à Groq (teste redatorTiraContatosEDocumentos); aviso nas telas de IA (print 3.7); seção "Como usamos IA" no site.
F-11	Integrante ausente / autonomia	Em andamento	Todos	Processo da equipe: cada integrante apresenta a sua frente na banca final. Ver retrospectiva (seção 8).
F-12	Estabilidade: paginar necessidades	Não feito	Luan	Era "Could": o tempo foi para os itens Must. Em compensação, a verificação achou e corrigiu um defeito maior (seção 3.10).
F-13	Elogios (time, inovação, pitch)	Won't	Equipe	Pontos fortes mantidos.
F-14	Cifrar todos os dados	Won't	Equipe	Justificativa na seção 5.3.
F-15	Conformidade LGPD completa (DPO, RIPD)	Won't	Gabriel	Exige pessoa jurídica. O que faltaria está na seção 5.4.

3. O que mudou, com as telas do sistema funcionando

3.1 Validação de campos (F-01 e F-02): "podia colocar o que quisesse em tudo"

Antes, a API só limitava o **tamanho** dos campos. Agora ela confere o **formato**, e as mesmas regras rodam nas três telas, para o erro aparecer antes de enviar. A API continua sendo a palavra final, porque qualquer um pode chamá-la sem passar pela tela. Os casos de teste são **idênticos** no Java e no Dart, o que prova que tela e servidor concordam.

Campo	Antes (aceito)	Agora
Telefone	"abc", "123"	DDD real (lista da Anatel), fixo começando de 2 a 5 ou celular começando com 9, com máscara (19) 99876-5432
CNPJ	qualquer texto com até 20 caracteres	dígitos verificadores conferidos, inclusive o CNPJ alfanumérico que a Receita adotou em julho de 2026
Nome / cidade	"!!!", "Jo4o"	só letras, espaço, hífen, apóstrofo e ponto

Campo	Antes (aceito)	Agora
Títulos e descrições	"12345", "<script>"	ao menos 2 letras e sem os caracteres < e >
Senha nova	6 caracteres na API; 4 na troca de senha do app, do painel e do site	8+ caracteres, com letras e números, fora da lista de senhas mais comuns — igual em todas as telas
Campanha	término antes do início; meta sem teto	término igual ou depois do início (até 2 anos); meta de até R\$ 10 milhões
Perfil (PUT)	nenhuma validação	nome, telefone, cidade, UF e bio validados; e-mail da ONG conferido; coordenadas entre -90/90 e -180/180



**Juntos, somos
MAIS
FORTES**

Doe itens e dinheiro para ONGs verificadas — e acompanhe o impacto real da sua ajuda.

Encontre necessidades perto de você, converse direto com a instituição e faça sua doação chegar a quem precisa.

ONGS DOADORES

Criar conta

Leva menos de um minuto.

Joana Silva

a@b.com

UF Cidade

(19) 8888-7777

••••••••

••••••••

☒ Li e aceito a Política de Privacidade e os Termos de Uso (LGPD).

Telefone: Telefone inválido: use DDD + número, ex.: (19) 99876-5432.

CRIAR CONTA E ENTRAR

Já tem conta? [Fazer login](#)

A API também responde campo a campo. Um cadastro com quatro erros devolve os quatro de uma vez:

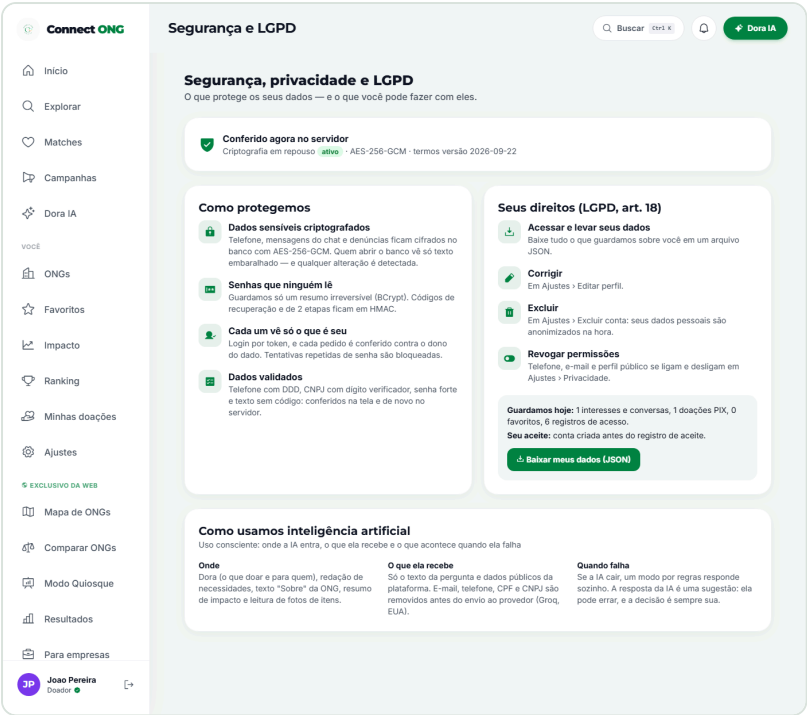
```
{"campos": {"nome": "Nome inválido: use apenas letras...", "senha": "A senha deve ter ao menos 8 caracteres...", "telefone": "Telefone inválido: use DDD + número...", "aceiteTermos": "É preciso aceitar os Termos..."}}
```

Print 3.1 — Cadastro no site recusando um telefone inexistente. Teste automatizado no navegador: nome com número, senha fraca e telefone inválido foram barrados, cada um com a sua mensagem, e o cadastro válido entrou direto na plataforma.

3.2 Criptografia de dados sensíveis (F-03)

- **O que é cifrado:** telefone das pessoas, mensagens do chat e texto das denúncias, com **AES-256-GCM**. O GCM também detecta adulteração: um byte trocado no banco faz a leitura falhar, em vez de devolver lixo.
- **Como:** um conversor JPA (`CampoCifradoConverter`) cifra ao gravar e decifra ao ler, então o resto do sistema não mudou. Cada valor ganha um IV aleatório: o mesmo telefone gravado duas vezes gera cifras diferentes.
- **Chave:** fica fora do código (`APP_CRYPTO_KEY`). O banco guarda a "impressão digital" da chave: um ambiente com a chave errada **não sobe**, em vez de misturar chaves e deixar dados ilegíveis.
- **Dados antigos:** os que já estavam em texto puro são cifrados automaticamente na inicialização, em lotes.
- **Códigos de recuperação de senha e de 2 etapas:** antes ficavam em texto puro; agora o banco guarda só o HMAC-SHA256 do código.

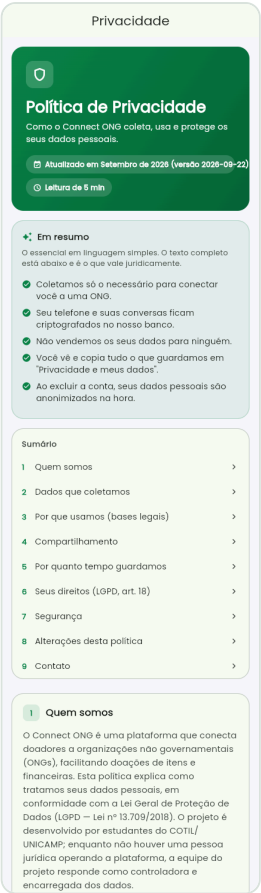
3.3 a 3.5 LGPD (F-04) e segurança explicada ao usuário (F-05)



Print 3.3 — Site, "Segurança e LGPD": status conferido ao vivo no servidor (criptografia ativa, versão dos termos), medidas de proteção, direitos do titular, "Baixar meus dados (JSON)" e "Como usamos inteligência artificial".



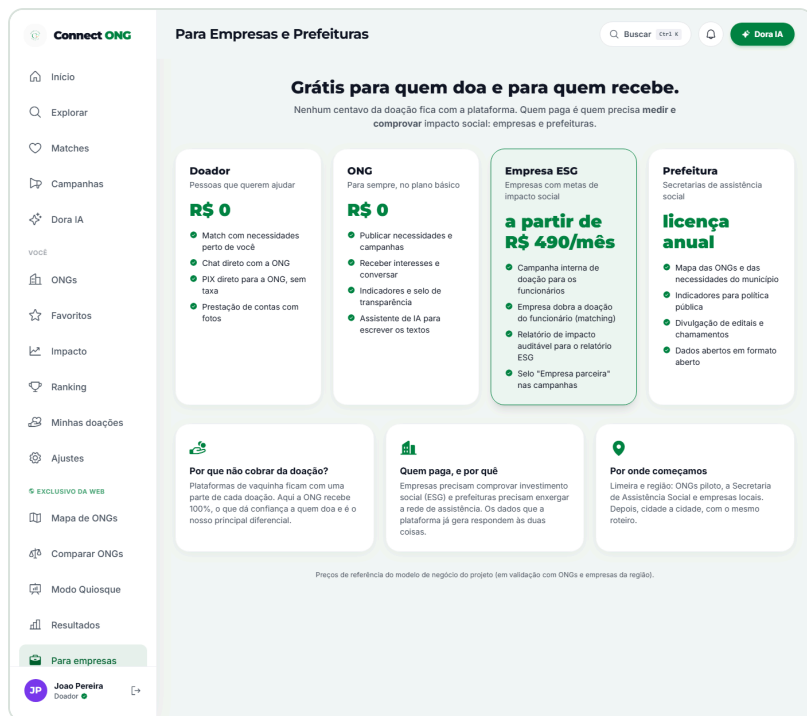
Print 3.4 — App do doador: "Privacidade e meus dados", com dados reais da conta e "Copiar meus dados (JSON)".



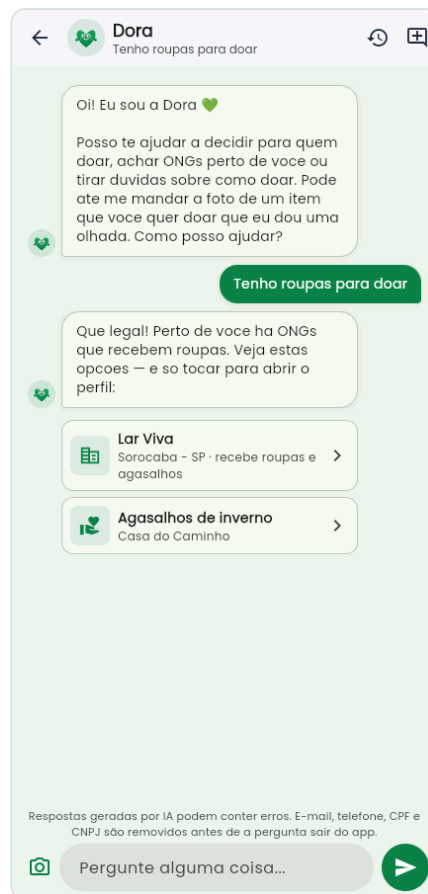
Print 3.5 — Política de Privacidade reescrita: bases legais, retenção, fornecedores fora do país e segurança.

Direitos do titular implementados. Consentimento com prova (art. 8º): o cadastro só passa com o aceite, gravado com versão, data e IP. **Acesso e portabilidade** (art. 18, II e V): exportação em JSON de conta, conversas, doações, favoritos, notificações e registro de acessos; a senha não sai, porque o sistema não a conhece. **Eliminação** (art. 18, VI): excluir a conta anonimiza nome, e-mail, telefone, cidade, bio e foto, e também o nome copiado nas avaliações e doações; o histórico continua sem identificar ninguém (art. 16). O painel da ONG tem a mesma tela e, no Windows, **salva o arquivo**.

3.6 e 3.7 Modelo de negócio no produto (F-07) e uso consciente da IA (F-10)



Print 3.6 — "Para empresas": grátis para quem doa e para a ONG; quem paga é empresa (ESG) e prefeitura. Detalhes na seção 4.



Print 3.7 — Dora no app: aviso de que a resposta é gerada por IA e de que dados pessoais não saem do app.

O que muda por trás do aviso

Antes de o texto de uma pessoa ir para a Groq, o backend troca e-mail, telefone, CPF e CNPJ por marcadores ([e-mail], [telefone]...). A IA entende que ali havia um contato, mas não recebe o dado (LGPD, art. 6º, III, necessidade). As instruções do sistema continuam intactas. Se a IA cair, o modo por regras responde; a decisão é sempre da pessoa.

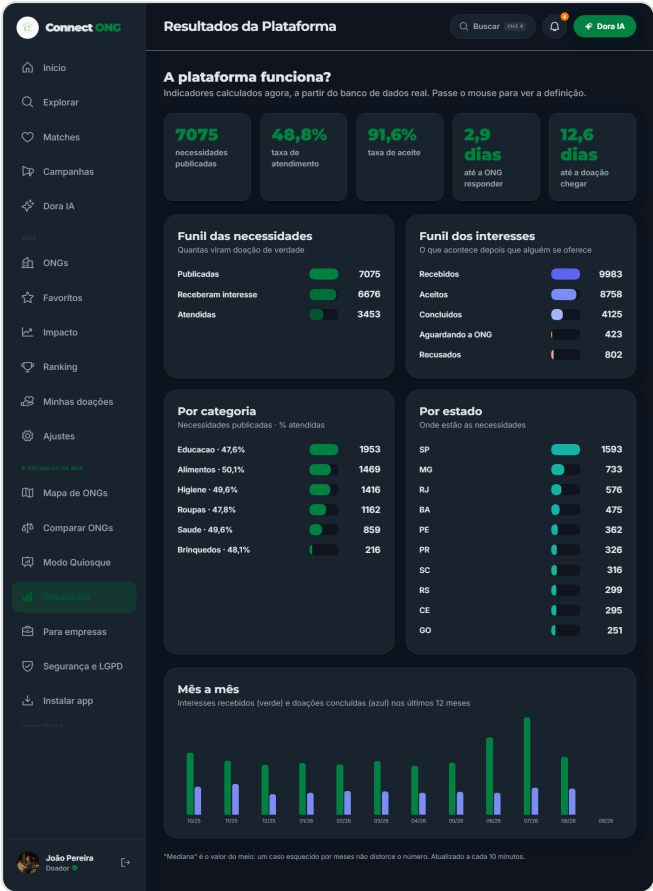
3.8 e 3.9 Análise de dados e resultados (F-08)

Antes, a plataforma só mostrava contagens soltas (quantas ONGs, quantos doadores). Agora ela responde se **a plataforma funciona**:

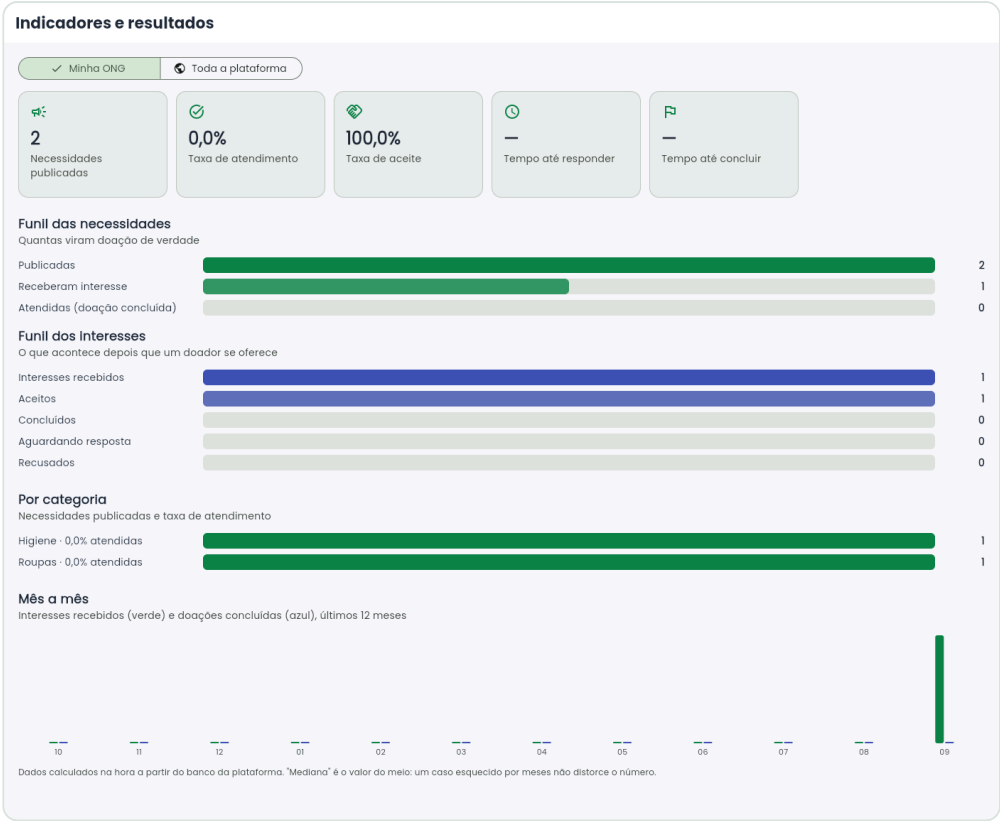
- **Funil:** necessidade publicada → recebeu interesse → atendida;
- **Taxas:** de atendimento e de aceite;

- **Tempos: mediana** de dias até a ONG responder e até a doação chegar;
- **Recortes:** por categoria, por estado e mês a mês.

Tudo sai em duas consultas ao banco (as agregações num único UNION ALL), por causa da regra de desempenho do projeto (cada ida ao banco custa ~600 ms no servidor gratuito).



Print 3.8 — Site publicado (connectong.netlify.app), "Resultados", calculado sobre a base da escola: 7.075 necessidades, taxa de atendimento de 48,8%, mediana de 2,9 dias até a ONG responder, as 27 UFs e 12 meses. A primeira consulta leva ~3 s; com o cache, 0,25 s.



Print 3.9 — Painel da ONG, "Indicadores e resultados": a ONG vê os próprios números e pode comparar com a plataforma inteira.

Sobre os números: a base da escola contém a **massa de demonstração** preparada para a feira (2.000 ONGs e 1.200 doadores fictícios, com histórico gerado). Os indicadores provam que o cálculo funciona em volume real; os números de **uso real** virão das ONGs piloto (F-09). O print 3.9 foi tirado com a base local de testes.

3.10 Achado da verificação: o site publicado estava fora do ar desde 01/09

Ao conferir as páginas novas no navegador, o console mostrou `Uncaught SyntaxError: Unexpected identifier 'let'`. Uma chave `}` a mais, entrada na véspera da feira (rolagem infinita da lista de ONGs), impedia o JavaScript inteiro de carregar. O site **publicado** só exibia o login, que não funcionava. A falha foi confirmada no endereço público, corrigida e verificada de novo. **Lição:** passar a checar o console do site automaticamente antes de publicar (ver retrospectiva).

4. Modelo de negócios (F-06): resposta a "pouco pensado para o mercado"

PROBLEMA ONGs pequenas não têm equipe de comunicação nem canal para pedir o item certo. Doadores não sabem onde doar e desconfiam do destino da doação. Empresas precisam comprovar investimento social e não têm como medir.	SOLUÇÃO Match entre a necessidade publicada e quem quer doar, chat direto, prestação de contas com fotos e indicadores de resultado.	PROPOSTA DE VALOR Doador: doar o que tem para quem precisa daquilo, perto de casa, e ver o resultado. ONG: receber o item certo, sem pagar nada e sem taxa sobre doação. Empresa: impacto social medido e comprovado para o relatório ESG. Prefeitura: enxergar a rede de assistência do município.	VANTAGEM DIFÍCIL DE COPIAR Os dados de resultado (quem atende, em quanto tempo, com prestação de contas) e o score de transparência, que crescem com o uso.	SEGMENTOS DE CLIENTES Usuários (grátis): doadores pessoa física e ONGs. Pagantes: empresas com metas de ESG e prefeituras.
ESTRUTURA DE CUSTOS Hospedagem da API e do banco (hoje em planos gratuitos; estimados cerca de R\$ 150 a 300 por mês com escala), uso de IA cobrado por volume, domínio, e o tempo da equipe (suporte e desenvolvimento).			FONTES DE RECEITA Plano Empresa ESG (a partir de R\$ 490/mês), licença anual para prefeituras e, no futuro, um plano "ONG Pro" opcional. TAXA ZERO SOBRE A DOAÇÃO.	

Concorrência e diferencial

Alternativa	O que faz	Onde o Connect ONG é diferente
Vaquinhas online (ex.: Vakinha)	Arrecadação em dinheiro para causas pessoais e sociais	Aqui o foco é a doação de itens com match e chat; a ONG recebe 100% do PIX, sem taxa da plataforma.
Financiamento coletivo (ex.: Benfeitoria)	Campanhas com meta e prazo	Relação contínua entre doador e ONG, não uma campanha isolada; prestação de contas com fotos.
Voluntariado (ex.: Atados)	Conecta voluntários a ONGs	Complementar: conectamos doações , com logística (frete) e transparência.

Alternativa	O que faz	Onde o Connect ONG é diferente
Ferramentas de captação para ONGs (ex.: Doare)	Sistema pago usado pela ONG	Grátis para a ONG: quem paga é o patrocinador que quer medir impacto.

Mercado

O Brasil tem **mais de 800 mil organizações da sociedade civil** (IPEA, Mapa das OSCs). A maioria é pequena e sem estrutura de captação: é o público do plano gratuito. A receita não depende de volume de doação, mas de dois clientes com orçamento definido: empresas (investimento social privado e relatórios ESG) e municípios (assistência social).

Entrada no mercado

Fase 1 — Limeira (piloto): 3 ONGs parceiras, Secretaria de Assistência Social e 2 empresas locais. **Fase 2 — Região de Campinas:** o mesmo roteiro, cidade a cidade. **Fase 3:** estados, com parcerias com redes de ONGs.

Metas do primeiro ano (hipóteses a validar com o F-09)

Indicador	Meta
ONGs ativas em Limeira	30
Doadores cadastrados	500
Taxa de atendimento das necessidades	40%
Empresas pagantes	2 (≈ R\$ 11,8 mil/ano)
Prefeitura com licença	1 (≈ R\$ 12 mil/ano)
Receita × custo de operação	≈ R\$ 24 mil × ≈ R\$ 3 mil/ano

Valores de referência para discussão com a banca. A validação com ONGs e empresas reais (F-09) é o próximo passo para confirmá-los.

Evolução do produto (potencial de aplicação)

PIX real por um provedor de pagamento (hoje simulado) · aplicativo nas lojas · integração com editais e chamamentos públicos · dados abertos para as prefeituras · relatório ESG automático para as empresas parceiras.

5. Segurança e LGPD: o documento que faltou na feira (F-05)

5.1 Camadas de proteção

Camada	Medida
Dados em repouso	AES-256-GCM no telefone, no chat e nas denúncias; senhas em BCrypt; códigos de verificação em HMAC-SHA256; chave fora do repositório, com trava de impressão digital.
Dados em trânsito	HTTPS em todos os endereços publicados (Render, Netlify, GitHub Pages).
Acesso	Login com token JWT (12 h) e refresh (7 dias); verificação em duas etapas opcional; cada pedido é conferido contra o dono do dado (quem tenta ler dado alheio recebe 403); papel de administrador que não pode ser criado pelo cadastro.
Abuso	Limite de tentativas no login, no cadastro, na recuperação de senha, nas doações e na IA (429 depois do limite); mensagens que não revelam se um e-mail existe.
Entrada de dados	Validação de formato na API e nas telas (seção 3.1); texto do usuário escapado ao ser exibido no site.
Privacidade	Telefone e e-mail só aparecem para quem a pessoa autoriza; bloqueio de doador; minimização de dados enviados à IA.
LGPD	Consentimento com prova, exportação dos dados, anonimização na exclusão, política com bases legais e retenção, registro de acessos.
Auditoria	Registro das ações sensíveis (login, troca de senha, troca de e-mail), sem nunca gravar senha ou código.

5.2 Conferir no sistema publicado

`GET https://connect-ong-api.onrender.com/publico/seguranca` mostra, sem nenhum segredo, as proteções ativas no servidor. A mesma informação aparece na página "Segurança e LGPD" do site.

5.3 Por que não cifrar todos os dados (F-14)

O **e-mail** é usado no login e precisa ser encontrado por igualdade; cifrado com IV aleatório, isso deixaria de funcionar. Os dados da **ONG** (nome, endereço, telefone institucional) são públicos por natureza. Esses dados já estão protegidos por HTTPS, controle de acesso por dono e senha com BCrypt.

5.4 O que falta para operar de verdade (F-15)

- Pessoa jurídica responsável e **encarregado de dados (DPO)** nomeado, com canal de atendimento ao titular.
- **Relatório de Impacto à Proteção de Dados (RIPD)**.
- Contratos com os fornecedores (hospedagem e IA) com cláusulas de proteção de dados.
- Plano de resposta a incidentes (comunicar a ANPD e os titulares).
- Rotina de troca periódica das chaves e de backup cifrado.

6. Testes e verificação

Frente	Antes	Agora	O que os testes novos provam
API (Java, JUnit)	191	231	Cada regra de formato; cadastro que exige aceite e grava o consentimento; exportação só para o dono; anonimização; telefone e mensagem cifrados no banco e legíveis na API; adulteração detectada; migração do legado; ambiente com a chave errada não sobe; indicadores conferidos número a número.
App do doador (Dart)	101	124	As mesmas regras da API, com os mesmos casos, e as máscaras de telefone e CNPJ.
Painel da ONG (Dart)	52	75	Idem.
Site (JavaScript)	—	navegador	Teste automatizado no Chrome: três cadastros inválidos barrados com a mensagem certa e um válido que entra na plataforma; console sem erros.

7. Roteiro do vídeo (5 a 10 minutos, seção 4.1)

Tempo	Bloco	O que aparece na tela	Quem fala
0:00–0:20	Abertura	Logo, nome da equipe e do projeto	Gabriel
0:20–0:50	O que ouvimos	Uma frase: a banca pediu interação; a feira apontou segurança, validação, LGPD, mercado e dados	Gabriel
0:50–1:30	O que a banca pediu (B-01 a B-04)	Doador demonstra interesse → ONG aceita no painel → o chat abre sozinho	Arthur
1:30–2:40	Validação (F-01, F-02)	Cadastro no site com nome "Jo4o", senha "123456" e telefone inválido e cadastro de ONG com CNPJ errado (Abner); a mesma recusa vinda da API (Luan)	Abner e Luan
2:40–3:50	Criptografia (F-03)	Mensagem enviada no chat → a mesma linha no banco aparece como <code>enc:v1:...</code> → no app aparece normal; <code>/publico/seguranca</code>	Gabriel
3:50–4:50	LGPD (F-04, F-05)	Aceite no cadastro, "Privacidade e meus dados", download do JSON, exclusão de conta de teste mostrando o nome anonimizado	Abner

Tempo	Bloco	O que aparece na tela	Quem fala
4:50–6:00	Resultados (F-08)	Site "Resultados" e painel "Indicadores": funil, taxa de atendimento, tempo de resposta, por estado	Luan
6:00–7:00	Mercado (F-06, F-07)	Slide do Lean Canvas (Arthur) e página "Para empresas" (Abner)	Arthur e Abner
7:00–7:30	IA consciente (F-10)	Aviso na Dora e a seção "Como usamos IA"	Gabriel
7:30–8:00	O que não entrou	F-09 (pesquisa com ONGs reais) e F-12 (paginação), com o motivo	Arthur e Luan
8:00–8:20	Próximo passo	"Até a banca final: validar com três ONGs de Limeira e fechar a primeira empresa parceira."	Todos

8. Retrospectiva da equipe (seção 4.3) — rascunho para a equipe revisar

O que funcionou

- Transformar o feedback num backlog com prioridade (MoSCoW) deixou claro o que atacar primeiro: segurança, validação e LGPD, as notas mais baixas.
- Testes automatizados e publicação automática: cada mudança só foi para o ar com as três suítes verdes.
- Conferir cada tela no navegador, e não só nos testes: foi assim que apareceu o site fora do ar desde a véspera da feira.

O que atrapalhou

- Um integrante ausente na feira pesou na nota de autonomia da equipe.
- Antes do backlog, as tarefas não tinham dono claro; parte do trabalho só ficava visível para quem o fez.
- Um defeito entrou na véspera da feira e ninguém percebeu por três semanas: faltava checagem automática do site publicado.
- A pesquisa com ONGs reais (F-09) depende de agenda externa e não coube no prazo.

O que vamos mudar até a banca final

- Cada item restante tem um dono, e cada integrante faz os próprios commits e apresenta a própria frente.
- Ensaio completo com os quatro presentes, incluindo o bloco de segurança e o de mercado.
- Checagem do console do site e da API publicada antes de cada apresentação.
- Visitar três ONGs de Limeira e aplicar o formulário aos doadores, para substituir as hipóteses da seção 4 por números reais.